NATIONAL PRIVACY COMMISSION

Primer on the Data Privacy Act (DPA) of 2012

ABCD-S:

"Awareness, Breach Management, Compliance, Data

Protection Officer and Security Measures“




© Hazel Thompson

Do not COLLECT if you cannot PROTECT

Who stores data about you?

facebook

YouTube









Google



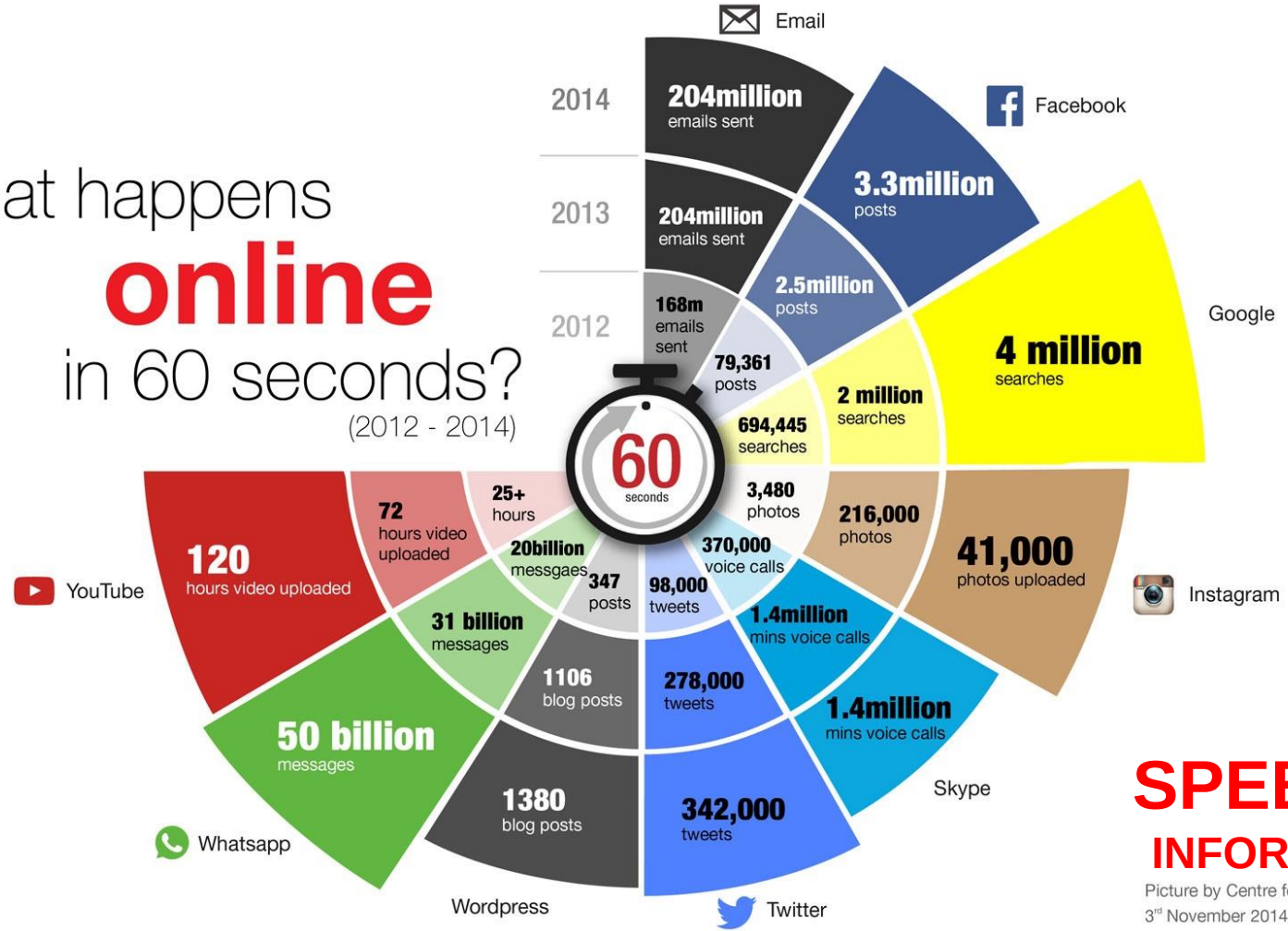
powered by ebay.co.uk

HSBC
The world's local bank

SM

What happens online in 60 seconds?

(2012 - 2014)



SPEED OF INFORMATION

Picture by Centre for Learning and Teaching
3rd November 2014

Which is more valuable?

Data

Money

“Data is more valuable than Money.

If someone takes your money, that's all they have. If you let someone take your data, they may eventually take your money too!“

from: Deputy Privacy Commissioner Dondi Mapa

NATIONAL PRIVACY COMMISSION

In today's environment, where competitors can copy your products, pirate your employees, and mirror your algorithms, **data** is the only **sustainable competitive advantage.**



FORMER
DEPUTY PRIVACY
COMMISSIONER
DAMIAN MAPA

What is the Data Privacy Act of 2012?

SECTION 1. Short Title. – This Act shall be known as the "**Data Privacy Act of 2012**".

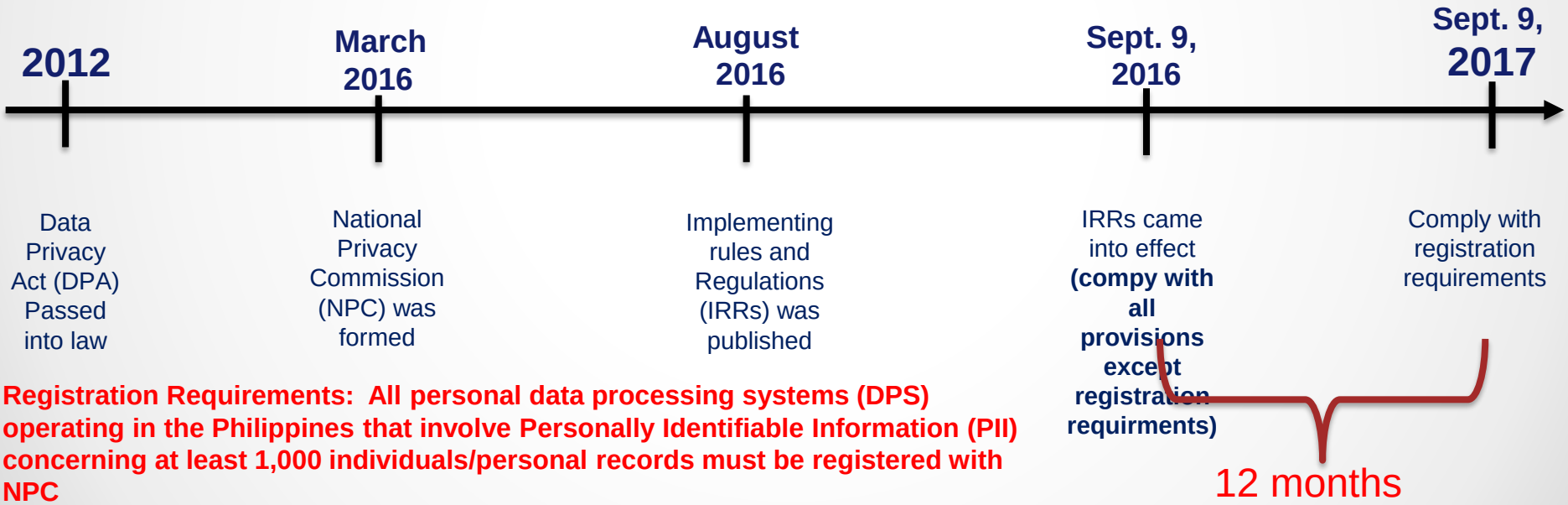
Republic Act 10173, the Data Privacy Act of 2012

AN ACT PROTECTING INDIVIDUAL PERSONAL INFORMATION IN INFORMATION AND COMMUNICATIONS SYSTEMS IN THE GOVERNMENT AND THE PRIVATE SECTOR, CREATING FOR THIS PURPOSE A NATIONAL PRIVACY COMMISSION, AND FOR OTHER PURPOSES

National Privacy Commission (NPC) is a body that is mandated to administer and implement this law. The functions of the NPC include:

- rule-making,
- advisory,
- public education,
- compliance and monitoring,
- investigations and complaints,
- and enforcement.

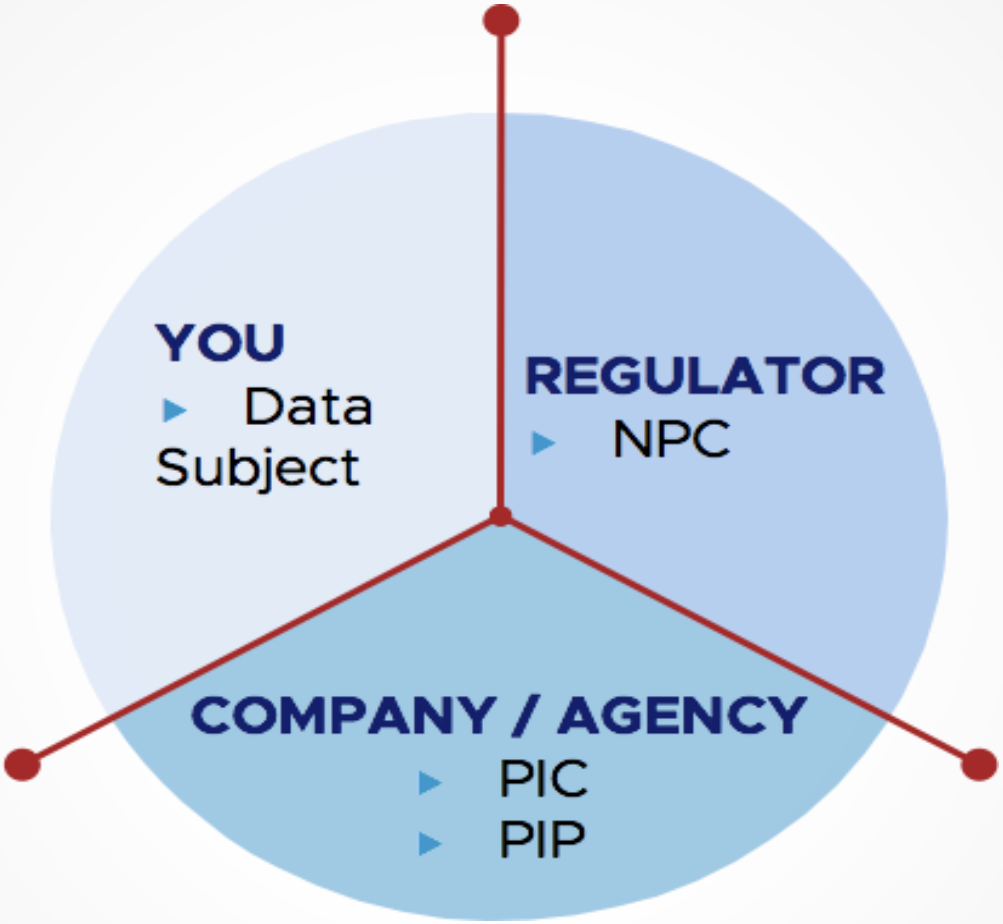
Timeline of DPA Law and IRRs passed to Organization's Compliance



Registration Requirements: All personal data processing systems (DPS) operating in the Philippines that involve Personally Identifiable Information (PII) concerning at least 1,000 individuals/personal records must be registered with NPC

KEY ROLES IN THE DATA PRIVACY ACT

- **Data Subjects**
  - Refers to an individual whose, sensitive personal, or privileged information is processed personal
- **Personal Information Controller (PIC)**
  - Controls the processing of personal data, or instructs another to process personal data on its behalf.
- **Personal Information Processor (PIP)**
  - Organization or individual whom a personal information controller may outsource or instruct the processing of personal data pertaining to a data subject
- **Data Protection Officer (DPO)**
  - Responsible for the overall management of compliance to DPA
- **National Privacy Commission**
  - Independent body mandated to administer and implement the DPA of 2012, and to monitor and ensure compliance of the country with international standards set for personal data protection


YOU
Data Subject
REGULATOR
NPC
COMPANY / AGENCY
PIC
PIP

Examples of Breaches and Live Cases

1. COMELeak (1 and 2)
2. BPI – consent form
3. Hospital – unsecure storage records
4. Student transferred by her parent without her knowledge
5. Clinical record of a student to disclose with her parents
6. List of top students/passers
7. Known Fastfood delivery – disclosing personal info of clients
8. No Data sharing agreement (DSA) between and among Schools and Universities
9. Cedula in malls
10. Security issues in buildings – logbook
11. Profiling of customers from a mall
12. Unjustifiable collection of personal data of a school
13. No Privacy Notice
14. Use of USB
15. Privacy notice
16. Use of USB
17. Personal laptop stolen
18. Lost a CD in transit
19. An error in viewing of student records in the online system
20. Use of re-cycled papers
21. Raffle stubs
22. Universities and Colleges websites with weak authentication
23. Personal Records stolen from home of an employee
24. Photocopiers re-sold without wiping the hard drives
25. Release of CCTV Footage
26. Hard drives sold online
27. Password hacked/revealed
28. Unencrypted Data

In the event of a data breach, we will not ask you how many millions you've spent on your hardware and IT experts.

We will, instead, ask whether you've implemented **NPC's five data privacy guidelines**.



PRIVACY COMMISSIONER AND CHAIRMAN RAYMUND E. LIBORO

NATIONAL PRIVACY COMMISSION

Potential Penalties listed in the Data Privacy Act

DPA Section	Punishable Act	For Personal Information	For Sensitive Personal Information	Fine (Pesos)
		JAIL TERM		
25	Unauthorized processing	1-3 years	3-6 years	500 k – 4 million
26	Access due to negligence	1-3 years	3-6 years	500 k – 4 million
27	Improper disposal	6 months – 2 years	3-6 years	100 k – 1 million
28	Unauthorized purposes	18 months – 5 years	2-7 years	500 k – 2 million
29	Intentional breach	1-3 years		500 k – 2 million
30	Concealment of breach	18 months – 5 years		500 k – 1 million
31	Malicious disclosure	18 month – 5 years		500 k – 1 million
32	Unauthorized disclosure	1-3 years	3-5 years	500 k – 2 million
33	Combination of acts	1-3 years		1 million – 5 million

Rights of the Data Subject

- Right to be informed - IRR, Section 34.a
- Right to object - IRR, Section 34.b
- Right to access - IRR, Section 34.c
- Right to data portability - IRR, Section 36
- Right to correct (rectification) - IRR, Section 34.d
- Right to erasure or blocking - IRR, Section 34.e
- Right to file a complaint - IRR, Section 34.a.2
- Right to damages - IRR, Section 34.f
- Transmissibility of Rights - IRR, Section 35

CLASSIFICATION OF PERSONAL DATA



Personal Information:

Personal information refers to any information whether recorded in a material form or not, from which the **identity of an individual is apparent or can be reasonably and directly ascertained by the entity holding the information**, or when put together with other information **would directly and certainly identify an individual**.



Sensitive Personal Information.

Refers to personal information about an individual's:

race, ethnic origin, marital status, age, color, religious, philosophical or political affiliations, health, education, genetics, sexual life, any proceeding for any offense committed or alleged to have been committed, the disposal of such proceedings, the sentence of any court in such proceedings;

Also includes information issued by government agencies peculiar to an individual which includes, but not limited to:

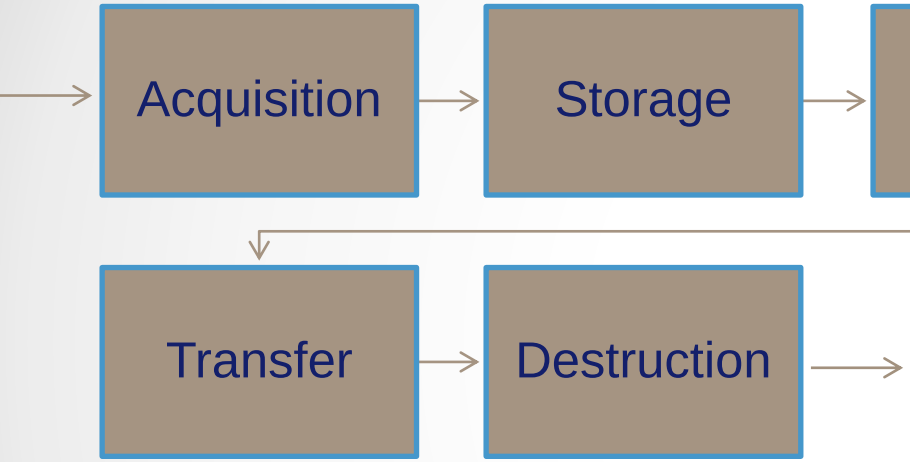
social security numbers, previous or current health records, licenses or its denials, suspension or revocation, and tax returns;

and specifically established by an executive order or an act of Congress to be kept classified.

Personal Information	**Sensitive Personal Information** (List based on IRR)	Privileged Information (List based on Rules of Court)
Name	Race	Data received within the context of a protected relationship – husband and wife
Address	Ethnic origin	
Place of work	Marital status	
Telephone number	Age	
Gender	Color	Data received within the context of a protected relationship – attorney and client
Location of an individual at a particular time	Religious affiliation	
IP address	Philosophical affiliation	
Birth date	Political affiliation	
Birth place	Health	Data received within the context of a protected relationship – priest and penitent
Country of citizenship	Education	
Citizenship status	Genetics	
Payroll & benefits information	Sexual life	
Contact information	Proceeding for any offense committed or alleged to have been committed, the disposal of such proceedings, the sentence of any court in such proceedings	Data received within the context of a protected relationship – doctor and patient

	Sensitive Personal Information (List based on IRR)	
	Social security number	
	Licenses or its denials, suspension or revocation	
	Tax returns	
	Other personal info issued by government agencies	
	Bank and credit/debit card numbers	
	Websites visited	
	Materials downloaded	
	Any other information reflecting preferences and behaviors of an individual	
	Grievance information	
	Discipline information	
	Leave of absence reason	
	Licenses or its denials, suspension or revocation	

Personal Data Lifecycle

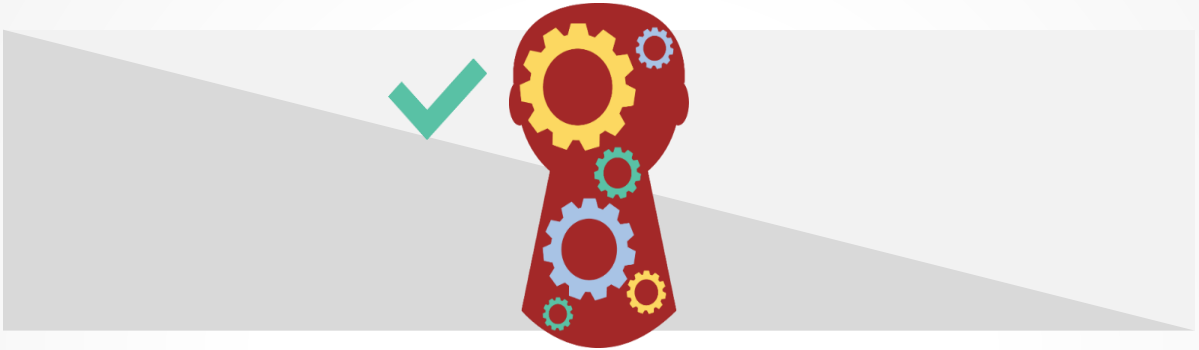


- Key considerations when listing your personal data:
  - What personal data do you collect?
  - In what form and through which channels?
  - For what purpose you collect personal data
  - How is it used?
  - Who is this data shared with internally and externally?
  - Who is authorized to access this data?
  - Where do you keep your data?
  - How long do you keep your data?
  - How do you dispose this data?

Retention/Disposal should be based on:

1. **Law**
2. **Industry Best Practice**
3. **Business Needs**

TRANSPARENCY – “the CONSENT Regime”



Principle of Transparency

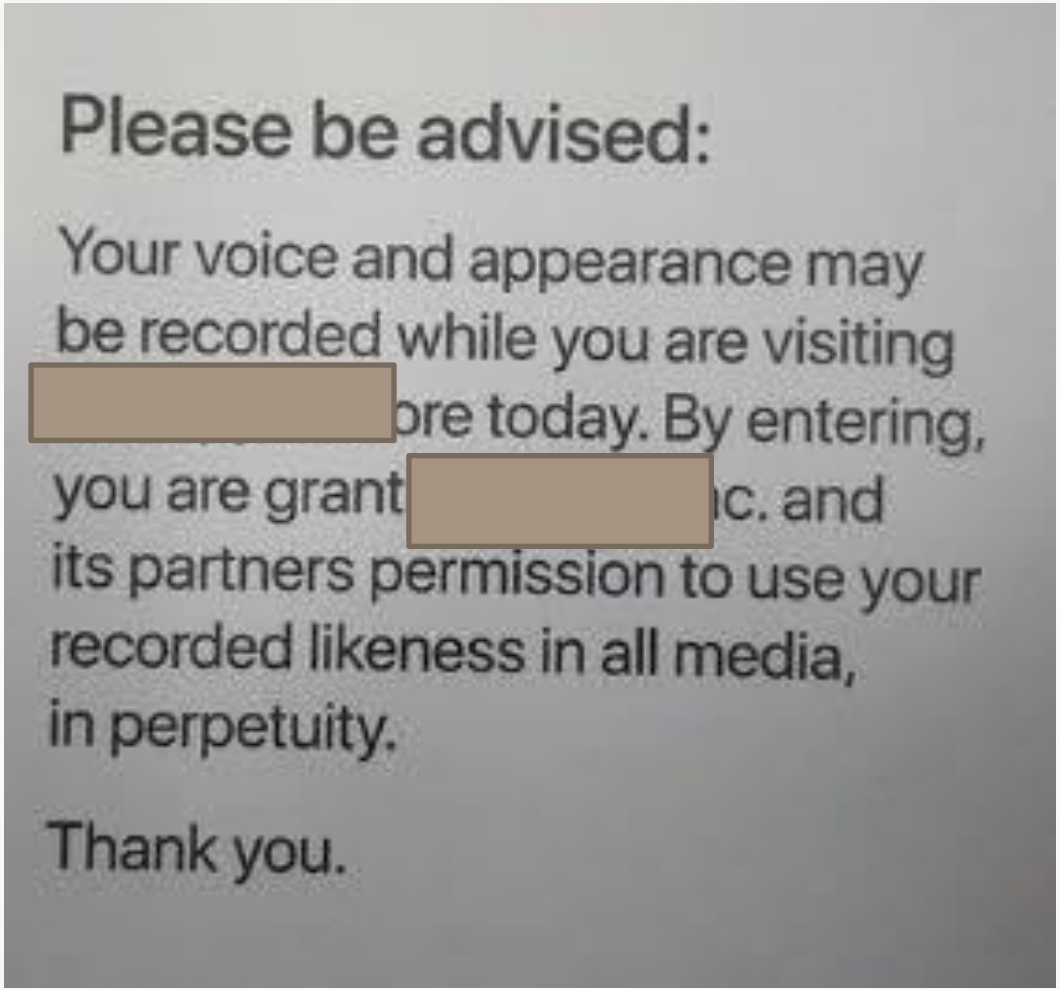
A data subject must be aware of the nature, purpose, and extent of the processing of his or her personal data, including the risks and safeguards involved, the identity of personal information controller, his or her rights as a data subject, and how these can be exercised. Any information and communication relating to the processing of personal data should be easy to access and understand, using clear and plain language.

LEGITIMATE PURPOSE



Principle of Legitimate Purpose

The processing of information shall be compatible with a declared and specified purpose, which must not be contrary to law, morals, or public policy.


Please be advised:
Your voice and appearance may
be recorded while you are visiting
[redacted]ore today. By entering,
you are grant[redacted]c. and
its partners permission to use your
recorded likeness in all media,
in perpetuity.
Thank you.

PROPORTIONALITY



Principle of Proportionality

The processing of information shall be adequate, relevant, suitable, necessary, and not excessive in relation to a declared and specified purpose. Personal data shall be processed only if the purpose of the processing could not reasonably be fulfilled by other means.

Avoid this mentality:
“just in case we need it”
“this is what we always do”



THE FIVE PILLARS OF COMPLIANCE

NATIONAL PRIVACY COMMISSION



Commit to Comply: Appoint a **Data Protection Officer (DPO)**



Know Your Risk: Conduct a **Privacy Impact Assessment (PIA)**

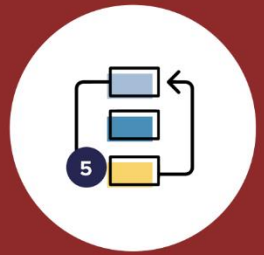


Be Accountable: Create your **Privacy Management Program** and **Privacy Manual**

NATIONAL PRIVACY COMMISSION



Demonstrate Your Compliance: Implement your **privacy and data protection (PDP)** measures.



Be Prepared for Breach: Regularly exercise your **Breach Reporting Procedures (BRP)**.

NATIONAL PRIVACY COMMISSION